

Reducing the risk — five ways to keep a network harder to break.

You can't make a network un-hackable. But you can make it expensive, slow and frustrating to attack — and quick to recover when something slips through. That's what risk reduction means.

What this key knowledge covers

This summary distils everything you need for **KK09 — Reducing the risk — five ways to keep a network harder to break.** in Cyber Security. Work through the explanations, then use the worked good-vs-weak answers to see exactly how marks are won and lost. Tick off the revision checklist at the end before a SAC or exam.

Study summary

Risk is likelihood × impact

Every security control does one of two jobs. It either makes a breach less likely to happen, or it makes the breach less damaging when it does. Knowing which job a control does is the single most useful idea in this whole topic — examiners test it constantly.

Reduce likelihood

Make it harder for an attack to succeed in the first place.

Reduce impact

Limit the damage and recover quickly once something gets through.

Defence in depth. No single control is enough. Attackers only need one gap; defenders need every layer to hold. So we stack independent controls so that if one fails, the next still stands. That stack is what the rest of this module builds, one layer at a time.

Clutch's defence stack

Here is Clutch's data core, wrapped in the five layers of KK09. Drag to rotate. Each ring is one risk-reduction method — when they're all closed and glowing emerald, an attacker has to defeat every layer in turn.

Firmware updates



Firmware is the low-level software baked into a device's chip that tells the hardware how to behave — the router, the modem, the office printer, the instructors' dash-cams. It's not an app you open; it runs the moment the device powers on.

Why it reduces risk: manufacturers release firmware updates to patch newly-discovered vulnerabilities and to remove insecure defaults. A router running three-year-old firmware often has publicly-listed exploits and ships with default admin passwords that attackers try first. Updating firmware reduces the likelihood of those known attacks landing.

For Clutch

Clutch's office router is the front door to the whole network. If its firmware is outdated, an attacker can exploit a known flaw to take control of traffic — including learners' licence numbers in transit. A scheduled quarterly firmware check on the router, modem and any smart devices closes that door.

Multi-factor authentication (MFA)

Multi-factor authentication requires two or more *independent* proofs of identity from different categories before granting access:

Password, PIN, passphrase.

Phone with an authenticator app, a code by SMS, a hardware key.

Fingerprint, face, other biometric .

Why it reduces risk: the most common breach starts with a stolen or guessed password. MFA makes a password alone useless — even with the correct password, the attacker is stopped because they don't have the second factor. It directly reduces the likelihood of unauthorised access.

Backups

A backup is a separate copy of data kept so it can be restored after loss — ransomware , a failed hard drive, a fire, or someone deleting the wrong folder. Backups are the one control on this list whose main job is to reduce impact, not likelihood. They don't stop the attack; they make it survivable.

The detail examiners want: a backup only helps if it is *recent*, *tested*, and *kept separate*. An untested backup that won't restore is worthless; a backup left plugged into the same network gets encrypted along with everything else.

Operating-system & anti-malware updates

Software ships with flaws nobody has found yet. When a flaw is discovered, the vendor releases a patch. The gap between a flaw becoming public and you installing the patch is the window of vulnerability — the period attackers race to exploit. Keeping operating systems and anti-malware software updated reduces the likelihood of those known exploits working.

OS updates

Fix security holes in Windows / macOS / Linux. Turn on automatic updates so the window of vulnerability stays short.

Anti-malware updates

Refresh the **signature database** so the scanner recognises the newest malware. Out-of-date anti-malware misses brand-new threats.

A flaw in Clutch's server OS goes public on Day 0. Choose how quickly Clutch patches.

Staff procedures — the human layer

The first four layers are technical controls. This one is different: it's an administrative (procedural) control — the rules, training and habits people follow. It matters because the strongest technology fails the moment a person clicks a phishing link, reuses a password, or props the metaphorical door open.

What good staff procedures look like at Clutch

Teach staff to spot phishing emails and report them, not click them.

Long, unique passphrases in a password manager — no sticky notes, no reuse.

Staff get only the access they need; accounts are disabled the day someone leaves.

A clear, blame-free way to report a mistake fast — this reduces *impact* when something slips through.

Defence Stack Lab

Switch Clutch's five controls on and off, then launch real-world attacks at the system. Watch which layer stops each attack — and watch the **residual risk** gauge move. Notice that backups never stop an attack; they change what happens *after* one lands.

Build a P-E-L answer

Top-band responses follow Point → Explain → Link : name the method, explain *how* it works, then link it to the scenario. Write each part below — the trainer highlights the key ideas examiners look for and scores your structure live.

P Multi-factor authentication requires two independent proofs of identity from different categories — for example a password plus a one-time code from an authenticator app. E This reduces the likelihood of unauthorised access because, even if an attacker steals or guesses a staff member's password, they still cannot log in without the second factor (the staff member's phone), which they do not possess. L For Clutch, applying MFA to the admin login protects learners' licence details and payment data from a credential-based attack.

- * 1 mark — states it needs two or more factors / proofs of identity
- * 1 mark — factors are from different/independent categories, with an example
- * 1 mark — backup = separate copy that can be restored after loss
- * 1 mark — reduces the IMPACT/consequence (not likelihood), linked to Clutch
- * 1 mark — one valid limitation (recency / untested / must be offline)
- * 1 mark — a valid similarity (both reduce likelihood / both needed for defence in depth)
- * 1 mark — difference in control TYPE (technical vs administrative)
- * 1 mark — difference in the THREAT each targets (device exploit vs human error)
- * 1 mark — link to Clutch / why both are needed
- * 1+1 marks — two appropriate methods recommended

- 1+1 marks — each justified against a specific threat Clutch faces
- 1 mark — reference to Clutch's data / acknowledges residual risk remains
- Up to 2 marks — strengths of anti-malware (reduces likelihood of known malware)
- Up to 3 marks — limitations: no defence in depth + specific gaps with named alternative controls (staff, MFA, firmware, backups)
- 1 mark — clear overall judgement (necessary but not sufficient)

Key terms

Term	Meaning
Command word	What the examiner wants
Identify / State	Name it. No explanation needed. 1 mark each.
Describe	Say what it is and a key feature — a sentence or two.
Explain	Give the <i>how</i> or <i>why</i> . Show cause and effect.
Compare	Both similarities <i>and</i> differences, side by side.
Justify	Give reasons for a choice; say why it's better than the alternative.
Evaluate	Weigh strengths <i>and</i> limitations, then make a judgement.

Common traps & misconceptions

Exam trap

❑ "It completely stops / prevents all attacks." No control is total. Write "reduces the likelihood" or "reduces the risk," never "eliminates" or "completely prevents." Residual risk always remains.

Exam trap

❑ Confusing firmware with OS updates. Firmware = chip-level software on a device (router, IoT). OS updates = the computer's operating system. They're separate layers — name the right one.

Exam trap

❑ Saying backups *prevent* a breach. Backups don't stop an attack happening — they reduce its **impact** by letting you recover. Get the likelihood-vs-impact distinction right.

Exam trap

❑ Listing without explaining. "Use MFA and backups" earns almost nothing on an Explain or Justify question. You must say *how* each control reduces the risk, and link it to the scenario.

Exam trap

❑ Forgetting the human layer. Students load up on gadgets and forget **staff procedures**. Naming the administrative control shows balanced understanding and often picks up a mark.

Exam trap

☐ Untested / connected backups. A backup that's never tested, or left plugged into the same network, fails when you need it. Strong answers note it must be recent, tested and kept offline/off-site.

How to answer exam questions

Read the **command word** first — it sets how much to write. *State/Identify* wants a word or phrase; *Describe* wants features; *Explain* wants reasons and links; *Justify/Evaluate* wants a judgement backed by evidence. Always pull in the **scenario detail** rather than answering in the abstract. The examples below contrast a weak response with a strong one for the same question.

Q1. Practice question · 2 marks

() — states it needs two or more factors / proofs of identity — factors are from different/independent categories, with an example

✗ A weak answer

It's when you log in using two passwords instead of one, so it's harder to break in. **Why it's weak:** Two passwords are the **same** factor ('something you know'), so this isn't multi-factor. No example of independent factors and no clear definition.

✓ A strong answer

Multi-factor authentication requires two or more independent proofs of identity from different categories before access is granted — for example, something you know (a password) plus something you have (a one-time code from a phone). **Why it works:** Defines 'two or more independent factors', specifies **different categories**, and gives a concrete example.

Q2. Practice question · 3 marks

() — backup = separate copy that can be restored after loss — reduces the IMPACT/consequence (not likelihood), linked to Clutch — one valid limitation (recency / untested / must be offline)

✗ A weak answer

Backups are good because if Clutch loses their data they can just get it back, so they should do backups. There aren't really any limitations. **Why it's weak:** Vague, no mechanism, doesn't say it reduces **impact** not likelihood, and gives no limitation (the question demands one).

✓ A strong answer

A backup is a separate copy of data, so if Clutch's database is lost to ransomware or a drive failure, it can be restored — this reduces the **impact** of the incident rather than its likelihood. A key limitation is that the restore is only as good as the most recent, tested backup; if it is out of date, untested, or left connected to the network it may be encrypted too and fail when needed. **Why it works:** Names the mechanism (restore a separate copy), correctly classifies it as reducing **impact**, links to Clutch, and gives a valid limitation.

Q3. Practice question · 4 marks

() — a valid similarity (both reduce likelihood / both needed for defence in depth) — difference in control TYPE (technical vs administrative) — difference in the THREAT each targets (device exploit vs human error) — link to Clutch / why both are needed

✗ A weak answer

Firmware updates update the router and staff procedures are rules for staff. Both help keep Clutch safe from hackers. **Why it's weak:** States what each is but barely compares. No similarity/difference structure, no control-type contrast, no link to the threats each addresses.

✓ A strong answer

Both reduce the **likelihood** of a breach, so they work together as part of defence in depth. They differ in type and target: firmware updates are a **technical** control that patches known flaws in Clutch's router and devices, defending against device-level exploits; staff procedures are an **administrative** control — training and policies — that defend against human-driven threats such as phishing and weak passwords. Firmware can't stop a staff member clicking a malicious link, and training can't patch a router, so Clutch needs both. **Why it works:** Gives a shared purpose (likelihood / defence in depth) AND two clear differences (technical vs administrative; device exploits vs human error), then links them.

Q4. Practice question · 5 marks

() 1+— two appropriate methods recommended 1+— each justified against a specific threat
Clutch faces — reference to Clutch's data / acknowledges residual risk remains

✗ A weak answer

They should use MFA and antivirus because they are the best and most secure options and everyone uses them. **Why it's weak:** Names choices but justifies with 'best / everyone uses them' rather than the specific threats. No link to Clutch's data and no acknowledgement of residual risk.

✓ A strong answer

I recommend **multi-factor authentication** and **backups**. MFA addresses Clutch's biggest exposure — credential theft on the admin login, which holds learners' licence details and payment data; even if a password is phished, the attacker can't log in without the second factor. Backups address the most damaging outcome for a small company, a ransomware attack: an offline, tested backup lets Clutch restore the logbook database instead of paying a ransom, reducing the impact to a few hours' work. Together these cover the most likely attack and the most costly one, though residual risk remains, so staff training should follow next year. **Why it works:** Two appropriate controls, each justified against a **specific named threat** and tied to Clutch's data, plus a realistic note on residual risk.